

Respuestas finales – Modelo de amenazas

Amenazas críticas y controles de arquitectura, desarrollo y monitoreo

Plataforma de e-commerce CompraFácil S.A.S.

Bootcamp Ciberseguridad – Módulo 2

Submódulo: Estrategias de arquitectura de seguridad

Mayo de 2026

1. ¿Qué amenazas críticas se identificaron y por qué? ¿Cuál es el riesgo asociado?

A lo largo de los seis flujos modelados, se identificaron amenazas con distintos niveles de severidad. Las que se consideran **críticas** son aquellas cuya materialización generaría pérdida financiera directa, incumplimiento regulatorio o compromiso total de la plataforma. Se priorizan a continuación.

1.1 Suplantación del proveedor de pagos (Flujo 4) – **CRÍTICO**

Amenaza. Un servidor malicioso suplanta la pasarela bancaria externa y envía al microservicio de pago confirmaciones falsas de cobro aprobado (R8 Flujo 4).

Por qué es crítica. Permitiría a un atacante recibir productos sin pagar; el ataque es *silencioso* (la orden parece exitosa) y solo se detectaría en conciliación bancaria con horas o días de retraso.

Riesgo asociado. Pérdida financiera directa, escalable mientras no se detecte. Daño reputacional si trasciende. Compromete la viabilidad del modelo de negocio.

1.2 Alteración de montos, IDs de orden o moneda en tránsito (Flujos 3 y 4) – **CRÍTICO**

Amenaza. Manipulación en memoria o en tránsito de variables transaccionales antes de enviar al proveedor (R8 Flujo 4); modificación del código del navegador para alterar montos (R8 Flujo 3); inyección de payloads corruptos al Gateway (R9 Flujo 3).

Por qué es crítica. Cualquiera de las tres vías produce el mismo efecto: cobrar menos de lo que el cliente debería pagar (o atribuir el cargo a otra orden).

Riesgo asociado. Fraude transaccional masivo; descuadre contable; potencial responsabilidad civil con clientes legítimos cuya orden sea reasignada.

1.3 Inyección SQL contra DB Órdenes / DB Productos (Flujos 2, 3, 4) – **CRÍTICO**

Amenaza. Inyección de comandos maliciosos para marcar como “Pagada” una orden rechazada (R10 Flujo 4), modificar precios o borrar inventario (R10 Flujo 2; R12 Flujo 3).

Por qué es crítica. Ataque clásico, ampliamente automatizado y bien documentado. Una sola consulta sin parametrizar deja expuesto el activo financiero más sensible del negocio.

Riesgo asociado. Compromiso total de la base transaccional; potencial RCE (escalación a ejecución remota); incumplimiento de protección de datos personales si se extraen tablas completas.

1.4 Extracción de llaves privadas del vault (Flujos 2, 3, 4, 6) – CRÍTICO

Amenaza. Lectura no autorizada de las llaves maestras o cadenas de conexión almacenadas en la Gestión de secretos (R11 Flujo 3; R9 Flujo 4).

Por qué es crítica. El vault custodia llaves de firma de JWT, credenciales de DB y certificados mTLS de la pasarela. Comprometerlo equivale a comprometer *todo el sistema* simultáneamente: un atacante podría firmar JWT válidos, conectarse a las DBs como servicio legítimo y autenticarse ante el banco.

Riesgo asociado. *Single point of catastrophic failure.* La materialización implicaría incidente nivel *P0* y muy probablemente notificación obligatoria a autoridades.

1.5 Ransomware sobre Backups protegidos (Flujo 3) – CRÍTICO

Amenaza. Borrado o cifrado malicioso de los archivos de copias de seguridad (R13 Flujo 3).

Por qué es crítica. Es la amenaza que destruye el último plano de defensa. Si coincide con un compromiso de producción, el negocio entra en pérdida irrecuperable.

Riesgo asociado. Cierre operativo prolongado; pérdida total de información histórica; potencial cese de actividades.

1.6 Filtración de PAN/CVV en logs (Flujo 4) – CRÍTICO

Amenaza. Registro accidental de datos confidenciales de tarjeta en texto plano dentro de archivos de log (R11 Flujo 4).

Por qué es crítica. Incumple PCI DSS. La materialización es habitual (uno de los OWASP API Top 10) por falta de sanitización en librerías de logs.

Riesgo asociado. Multas regulatorias (PCI: USD 5 000–100 000 mensuales; legislaciones locales pueden agregar más); pérdida de la capacidad de procesar pagos si se revoca el contrato con la pasarela.

1.7 Suplantación del Frontend (phishing/clonado del checkout) (Flujos 2, 3) – ALTO

Amenaza. Atacante clona la interfaz de checkout en un dominio falso para capturar datos del cliente (R8 Flujo 3); clona el catálogo con precios falsos (R7 Flujo 2).

Por qué es alta. El impacto recae sobre el cliente, no directamente sobre CompraFácil, pero el daño reputacional al negocio es severo.

Riesgo asociado. Captura masiva de credenciales y datos personales de clientes; pérdida de confianza en la marca.

1.8 Elevación de privilegios sobre el SIEM (Flujos 3, 4, 5) – ALTO

Amenaza. Acceso no autorizado a la consola del SIEM para borrar logs o desactivar alarmas (R12 Flujo 2; R14 Flujo 3; R11 Flujo 4).

Por qué es alta. Permite *encubrir* otras amenazas, lo que vuelve imposible la respuesta a incidentes.

Riesgo asociado. Pérdida de capacidad forense; incumplimiento de la obligación de auditoría; potenciales sanciones regulatorias por incapacidad de demostrar diligencia.

1.9 Denegación de servicio contra el API Gateway / catálogo (Flujos 2, 3, 4) – ALTO

Amenaza. Inundación del Gateway o del endpoint de checkout para bloquear el procesamiento de pagos legítimos (R9 Flujo 3; R7 Flujo 4).

Por qué es alta. El e-commerce no genera ingresos durante la caída. Costo proporcional al *downtime*.

Riesgo asociado. Pérdida de ingresos directa; abandono de carrito; daño reputacional.

1.10 Acceso no autorizado a transacciones de otros clientes (Flujo 3) – ALTO

Amenaza. Fallas en la validación del token de sesión que permiten a un cliente ver órdenes de otros (R10 Flujo 3 – IDOR).

Por qué es alta. Vulneración directa de protección de datos personales (Habeas Data en Colombia, GDPR si hay clientes europeos).

Riesgo asociado. Multas regulatorias; demandas civiles; obligación de notificar a los titulares afectados.

1.11 Cuadro resumen

Amenaza	Nivel	Riesgo principal
Suplantación del proveedor de pagos	CRÍTICO	Pérdida financiera silenciosa
Alteración de montos transaccionales	CRÍTICO	Fraude / descuadre contable
Inyección SQL en DBs transaccionales	CRÍTICO	Compromiso total de datos
Extracción de llaves del vault	CRÍTICO	Compromiso global del sistema
Ransomware sobre backups	CRÍTICO	Pérdida irrecuperable
Filtración PAN/CVV en logs	CRÍTICO	Multas PCI DSS
Suplantación del Frontend	ALTO	Phishing / pérdida de confianza
Elevación de privilegios sobre SIEM	ALTO	Encubrimiento forense
DoS al Gateway / checkout	ALTO	Lucro cesante
Acceso a transacciones ajenas (IDOR)	ALTO	Sanciones por protección de datos

2. ¿Qué controles de arquitectura se propusieron e implementaron y por qué?

Los *controles de arquitectura* son aquellos que viven en la **infraestructura, la red y los servicios de plataforma**, antes de que el código de aplicación se ejecute. Son la primera línea de defensa.

2.1 TLS/HTTPS extremo a extremo

Qué. Certificados TLS firmados por CA reconocida en todas las interfaces externas (R35 Flujo 2, R37 Flujo 3).

Por qué. Evita ataques de *Man-in-the-Middle* (MitM) entre el navegador y el frontend, y entre microservicios e integraciones externas. Es la base de todos los demás controles (sin TLS, la suplantación y la alteración en tránsito son triviales). Refuerza el supuesto **S1** del workshop.

2.2 Autenticación mutua TLS (mTLS) con la pasarela bancaria

Qué. Certificados mutuos entre microservicio de pago y servidor del proveedor (R40 Flujo 4).

Por qué. Mitiga la amenaza crítica de *suplantación del proveedor de pagos*. El atacante necesitaría no solo conocer la URL del banco sino poseer un certificado válido firmado por la CA del banco, lo cual es operativamente inviable.

2.3 Segmentación de red por zonas de confianza

Qué. Aislamiento físico/lógico en zonas: aplicación, microservicios, datos, secretos, respaldo y auditoría (visible en el diagrama de arquitectura).

Por qué. Las DBs, el vault y los backups *no son alcanzables desde Internet*. Esto justifica directamente la exclusión de varios riesgos y sobre almacenes (supuesto **S6** del workshop). Materializa el principio de defensa en profundidad.

2.4 API Gateway como único punto de ingreso

Qué. Todo el tráfico externo pasa por el Gateway antes de llegar a los microservicios.

Por qué. Permite concentrar los controles perimetrales (rate limiting, mitigación DDoS, validación de esquemas, IP whitelisting) en un solo componente, evitando que cada microservicio reimplemente seguridad perimetral. Reduce drásticamente la superficie de ataque.

2.5 Rate limiting y mitigación DDoS perimetral

Qué. Umbrales máximos de peticiones por IP en el Gateway y en el servidor del Frontend (R41 Flujo 2, R47 Flujo 3).

Por qué. Es la única defensa viable contra DoS volumétrico hacia el e-commerce. Sin él, un único bot podría bloquear el checkout.

2.6 IP Whitelisting para callback del proveedor de pagos

Qué. El Gateway solo acepta callbacks de pago provenientes de los rangos IP oficiales de la pasarela (R38 Flujo 4).

Por qué. Elimina la mayoría de los vectores externos para enviar webhooks fraudulentos. Es complemento de la validación de firma (control de desarrollo, ver §??).

2.7 Aislamiento estricto de bases de datos (VPC privada + firewall)

Qué. Las DBs solo aceptan conexiones del microservicio dueño, por IP privada (R64 Flujo 3, R55 Flujo 4).

Por qué. Materializa el principio de mínimo privilegio en la capa de red. Aunque un microservicio fuera comprometido, las DBs de otros dominios siguen protegidas.

2.8 Cluster de alta disponibilidad para Gestión de secretos

Qué. Vault desplegado en HA con conmutación por error (failover) y caché local (R63 Flujo 2, R59 Flujo 3, R50 Flujo 4).

Por qué. Sin el vault, ningún microservicio puede conectarse a su DB ni firmar JWTs. Es un componente *críticamente compartido* y debe tener disponibilidad superior al resto del sistema.

2.9 Almacenamiento WORM para backups

Qué. Configuración *Write-Once-Read-Many* (inmutabilidad estricta) en el repositorio de respaldos (R71 Flujo 3).

Por qué. Mitiga directamente la amenaza crítica de *ransomware sobre backups*. Por diseño del producto, los archivos no pueden ser alterados ni borrados durante su período de retención.

2.10 Cifrado en reposo AES-256

Qué. Backups y secretos cifrados con AES-256 con llaves custodiadas en bóveda (R70 Flujo 3).

Por qué. Cuando los datos están en reposo, el cifrado es la única defensa frente a la fuga del soporte físico (disco, snapshot, bucket mal configurado). Es requisito de PCI DSS para datos financieros.

2.11 SSO + MFA + RBAC para acceso administrativo

Qué. Integración con directorio activo corporativo y autenticación multifactor; control de acceso basado en roles para SIEM y panel administrativo (R63 Flujo 4, R78 Flujo 3).

Por qué. Mitiga la amenaza alta de *elevación de privilegios sobre el SIEM* y la suplantación del administrador. El MFA hace que el robo de contraseña no sea suficiente para tomar control.

3. ¿Qué controles de desarrollo se propusieron e implementaron y por qué?

Los *controles de desarrollo* son los que residen en el **código de los microservicios y del frontend**. Se aplican durante construcción y se validan en el pipeline CI/CD.

3.1 Sentencias parametrizadas / ORM en la capa de datos

Qué. Uso obligatorio de *prepared statements* u ORMs; bloqueo de sentencias SQL dinámicas (R54 Flujo 2, R62 Flujo 3, R53 Flujo 4).

Por qué. Mitiga directamente la amenaza crítica de *inyección SQL*. Es el único control efectivo: ni el WAF ni los firewalls bloquean confiablemente todas las variantes de SQLi.

3.2 Validación estricta de esquemas JSON en el API Gateway

Qué. Rechazo de peticiones malformadas o con tipos inválidos antes de llegar a los microservicios (R42 Flujo 2, R44 Flujo 3, R35 Flujo 4).

Por qué. Mitiga la *alteración en tránsito* con payloads corruptos. Equivale a un *schema firewall*: lo que no coincide con el contrato, no pasa.

3.3 Recálculo lógico de montos y totales en el backend

Qué. El backend ignora los valores numéricos enviados por el cliente y recalcula totales, impuestos y subtotales desde la fuente autoritativa (R50 Flujo 3).

Por qué. Mitiga la amenaza crítica de *alteración de montos transaccionales* aun cuando el atacante manipule el frontend. Aplica el supuesto **S3** (“el frontend no es confiable”).

3.4 Validación criptográfica de firmas de webhook

Qué. Verificación de firmas SHA-256 provistas por la pasarela en cada callback de pago (R35 Flujo 4).

Por qué. Junto con mTLS e IP Whitelisting, completa la defensa contra *suplantación del proveedor de pagos*. Aunque el atacante lograra emitir desde una IP válida, no podría firmar el webhook sin la llave del banco.

3.5 Cifrado del payload transaccional en capa de aplicación

Qué. Cifrado AES-256 e inmutabilidad de variables (monto, ID de orden, moneda) antes de enviarlas al banco (R41 Flujo 4).

Por qué. Defensa en profundidad contra alteración: aunque alguien lograra interceptar la conexión mTLS, el payload sigue cifrado a nivel de aplicación.

3.6 Tokenización en el flujo de pagos (no almacenar PAN ni CVV)

Qué. Decisión de diseño: los datos primarios de tarjeta nunca residen en CompraFácil; viajan directamente a la pasarela.

Por qué. Reduce el alcance regulatorio de PCI DSS a SAQ-A y elimina la mayor parte de las amenazas de confidencialidad sobre datos financieros.

3.7 Sanitización y enmascaramiento de logs

Qué. Políticas automáticas en las librerías de logs del microservicio de pago para truncar PAN/CVV; en órdenes y autenticación, omitir tokens y datos personales (R61 Flujo 4, R76 Flujo 3, R68 Flujo 2).

Por qué. Mitiga directamente la amenaza crítica de *filtración de PAN/CVV en logs*. Es el control que más comúnmente falla por descuido del desarrollador.

3.8 Validación de firma y vigencia del JWT + aislamiento por usuario

Qué. Cada microservicio valida la firma del JWT, lee los *claims* (rol, scope, subject) y restringe consultas para que un usuario solo acceda a sus propios recursos (R52 Flujo 3).

Por qué. Mitiga la amenaza alta de *acceso a transacciones de otros clientes* (IDOR). Sin esta validación, el JWT autenticaría pero no autorizaría correctamente (supuesto S4).

3.9 DTOs con omisión de campos sensibles

Qué. Esquemas de respuesta lógicos (Data Transfer Objects) que omiten campos internos como costos, márgenes o IDs de proveedor (R47 Flujo 2).

Por qué. Mitiga la *revelación de información* por sobre-exposición en respuestas. Patrón estándar de hardening de APIs.

3.10 Enmascaramiento global de excepciones técnicas

Qué. El Gateway retorna códigos HTTP genéricos hacia el exterior, ocultando trazas, rutas internas y estructura del backend (R44 Flujo 2, R46 Flujo 3, R37 Flujo 4).

Por qué. Niega información valiosa al atacante en fase de reconocimiento (*security through obscurity* no es la defensa principal, pero sí una capa válida).

3.11 Minificación y limpieza del código JavaScript del frontend

Qué. Pipeline de compilación que remueve comentarios de desarrollo, endpoints de prueba, ofuscación (R38 Flujo 2, R40 Flujo 3).

Por qué. Mitiga la *revelación de información* por inspección del navegador. Aplica el supuesto S3.

3.12 Eliminación de scripts/menús administrativos en el código de cliente

Qué. El frontend público no contiene botones, rutas ni JS de administración (R42 Flujo 3).

Por qué. Mitiga la *elevación de privilegios* por manipulación del DOM. Si el código no existe en el cliente, no puede ser activado mediante inspección.

3.13 Procedimientos almacenados con row-locking

Qué. Transacciones atómicas aisladas con bloqueo de fila para impedir cambios concurrentes maliciosos (R53 Flujo 4).

Por qué. Mitiga la inyección lógica que marca una orden como “Pagada” por carrera o por inyección. Las transacciones atómicas garantizan integridad ACID.

4. ¿Qué controles de monitoreo se propusieron e implementaron y por qué?

Los *controles de monitoreo* son los que permiten **detectar, alertar y auditar** cuando algo se desvía del comportamiento esperado. Su rol no es prevenir, sino *ver*.

4.1 SIEM centralizado con append-only

Qué. Componente central que recibe los eventos de seguridad y auditoría de todos los microservicios y del panel administrativo. Diseño *append-only* con firmas/hashing de integridad.

Por qué. Único punto de la verdad para auditoría y forense. Su naturaleza inmutable lo convierte en el control de no repudio para todo el sistema. Materializa los supuestos **S8** y **S10** del workshop.

4.2 Monitoreo automatizado de certificados TLS y mTLS

Qué. Alertas automáticas sobre expiración, revocación y handshakes fallidos de certificados (R35 Flujo 2, R40 Flujo 4).

Por qué. La expiración silenciosa de un certificado degrada o detiene el servicio sin causa aparente. Detectarla con antelación es crítico operativo.

4.3 Auditoría automatizada de accesos al vault

Qué. Registro y alarmas sobre cada lectura de secretos del vault (R62 Flujo 2, R46 Flujo 4).

Por qué. Cualquier acceso al vault fuera de los servicios autorizados es señal de compromiso. Es el último anillo antes de la fuga de llaves.

4.4 Bloqueo y alerta ante sentencias SQL dinámicas

Qué. El motor de DB bloquea y alerta cuando detecta sentencias dinámicas no parametrizadas (R54 Flujo 2, R62 Flujo 3, R53 Flujo 4).

Por qué. Detección complementaria al control preventivo. Si un desarrollador rompe la regla en una nueva ruta, la DB lo bloquea inmediatamente.

4.5 Monitoreo de discrepancias matemáticas con la pasarela

Qué. Alertas cuando el valor local calculado por el microservicio de pago difiere del valor procesado por la pasarela (R41 Flujo 4).

Por qué. Detecta en *tiempo casi real* la alteración de montos transaccionales. Es la red de seguridad final si todos los controles preventivos fallaran.

4.6 Métricas de tráfico, CPU, ancho de banda y respuesta del Gateway

Qué. Monitoreo continuo de saturación, falsos positivos en rate limiting y degradación (R41 Flujo 2, R47 Flujo 3, R38 Flujo 4).

Por qué. Permite distinguir entre tráfico legítimo y un DDoS en curso. Sin estas métricas, la respuesta a incidentes es ciega.

4.7 Alertas críticas de capacidad del SIEM

Qué. Notificaciones automáticas cuando el almacenamiento del SIEM supera el 80% (R69 Flujo 2, R77 Flujo 3, R62 Flujo 4).

Por qué. Mitiga la amenaza alta de *saturación intencional del SIEM* con eventos masivos. Si el SIEM se llena, el sistema pierde visibilidad y un atacante puede operar sin ser registrado.

4.8 Heartbeats y monitoreo de replicación del vault

Qué. Monitoreo periódico de latidos, consistencia de datos e índices de salud entre nodos del cluster de secretos (R63 Flujo 2, R59 Flujo 3, R50 Flujo 4).

Por qué. El vault es un componente crítico compartido; detectar pérdida de sincronización temprano evita una caída total.

4.9 Auditoría mensual de cuentas privilegiadas en el SIEM

Qué. Revisión periódica del listado de identidades con permisos de modificación o borrado en el SIEM (R70 Flujo 2, R78 Flujo 3, R63 Flujo 4).

Por qué. Mitiga la amenaza alta de *elevación de privilegios sobre el SIEM*. Si una cuenta deja la organización o cambia de rol y conserva accesos, se detecta en la revisión.

4.10 Pruebas de Seguridad (Red Team) sobre controles privilegiados

Qué. Pruebas adversariales contra los puntos críticos (RBAC del SIEM, validación mTLS, integridad de logs) (R70 Flujo 2, R78 Flujo 3, R63 Flujo 4).

Por qué. La única forma de validar empíricamente que los controles funcionan bajo presión real. Complementa las pruebas funcionales y automatizadas.

4.11 Pruebas de simulación de restauración de backups

Qué. Ejercicios periódicos de restauración de bases de datos a partir de los archivos de respaldo (R71 Flujo 3).

Por qué. “Un backup que no se ha restaurado no es un backup.” Detecta corrupciones silenciosas, fallas de procedimiento y degradaciones de cifrado antes de que se necesiten en un incidente real.

4.12 Escaneo periódico de configuraciones de buckets/contenedores

Qué. Verificación automatizada de ausencia de acceso público en repositorios de respaldo y configuraciones de red (R70 Flujo 3, R64 Flujo 3).

Por qué. La mayoría de las fugas de datos públicas recientes han sido por buckets mal configurados. El escaneo periódico previene drift de configuración.

4.13 Revisión periódica de muestras de logs

Qué. Inspecciones manuales y automatizadas de muestras de trazas indexadas en el SIEM (R68 Flujo 2, R76 Flujo 3, R61 Flujo 4).

Por qué. Detecta filtraciones accidentales de PAN, CVV o tokens en logs antes de que sean explotadas. Es complemento detectivo del control preventivo de sanitización.

5. Síntesis – Mapa amenaza → controles

Amenaza crítica	Control arquitectura	de	Control desarrollo	de	Control monitoreo	de
Suplantación de la pasarela	mTLS, Whitelisting	IP	Validación de firma de webhook		Monitoreo de handshakes mTLS	
Alteración de montos	TLS extremo extremo	a	Recálculo en backend; cifrado de payload		Monitoreo de discrepancias matemáticas	
SQLi en DBs transaccionales	Aislamiento de red		Sentencias parametrizadas		Bloqueo automatizado de SQL dinámico	
Extracción de llaves del vault	Cluster HA del vault; mínimo privilegio		App-role y token dinámico		Auditoría de cada lectura de secretos	
Ransomware sobre backups	WORM; AES-256	cifrado	—		Pruebas de restauración	
Filtración PAN/CVV en logs	—		Sanitización en librerías de logs		Inspección periódica de muestras	
DoS al Gateway	Rate limiting; mitigación DDoS		—		Métricas de CPU/red	
Acceso a transacciones ajenas	—		Validación de JWT + aislamiento por usuario		Trazabilidad de accesos denegados	
Elevación de privilegios en SIEM	SSO + MFA + RBAC		—		Red Team mensual; auditoría de cuentas	

Lectura del mapa. Cada amenaza crítica está cubierta por al menos dos capas (arquitectura + desarrollo, o arquitectura + monitoreo). Las que no aparecen en una de las columnas indican explícitamente **en qué nivel no corresponde aplicar el control**, lo cual es deliberado y se alinea con los supuestos del modelo (por ejemplo, los backups no requieren control de desarrollo porque son un activo de infraestructura).

Este documento complementa `justificaciones.tex` y `supuestos_inferidos.tex` y cierra la trazabilidad amenaza → supuestos → controles del modelo de amenazas STRIDE de CompraFácil S.A.S.